

Penetration Test Report: cs456-194
Author: Habit Blunk
Date of Assessment: 2025-12-07
Version: 1.0

Executive Summary

Overview

A penetration test was conducted against the target virtual machine to identify and assess security vulnerabilities within its containerized services. The assessment revealed some security weaknesses, including one critical vulnerability that allowed for remote login and system compromise.

High-Level Test Outcomes

The test was successful in achieving its objectives. The engagement resulted in user-level access to a container running a vulnerable SSH service. This access could be leveraged to elevate privileges on the host VM and potentially the broader network.

Overall Risk Rating

Overall Risk Rating: Critical

The presence of a remotely exploitable vulnerability that grants an attacker user control with the possibility of privilege escalation warrants a critical rating. This single point of failure compromises the security of the entire VM.

Prioritized Recommendations

1. Immediately update or replace the vulnerable SSH container.
2. Change user and root passwords; enforce a strong, regularly changing password policy for the SSH service to protect against brute-force attacks.

Test Scope and Methodology

Scope

The scope of this pen test was limited to the VM and its services at the IP address 192.168.0.194.

Methodology

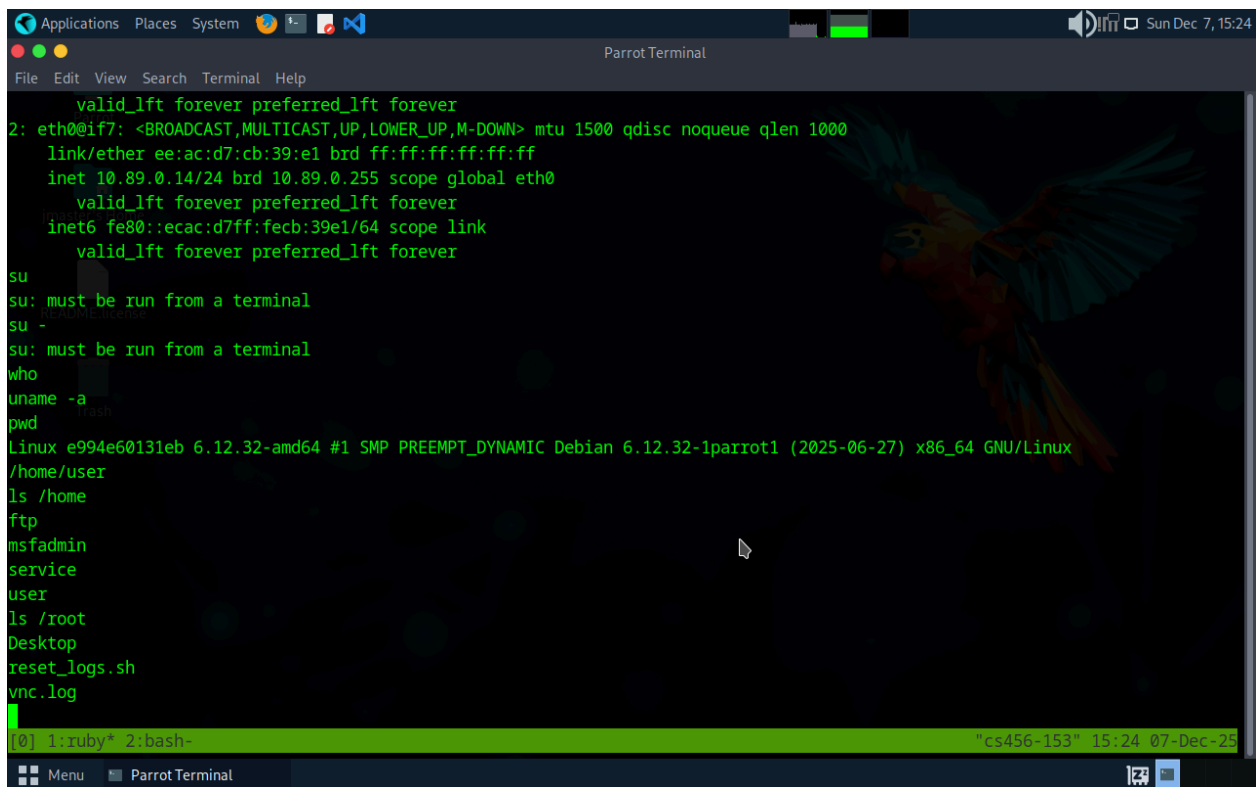
The assessment followed a standard pen testing methodology. First, I used the Metasploit built-in `db_nmap` command to identify ports and running services. Next, I identified the

vulnerable SSH service with an automated scanner and doing research on each service. Finally, I exploited the vulnerable SSH service to demonstrate impact.

Detailed Findings

3.1. Finding 1: Remote Shell via Brute-Forced SSH Service

- Risk rating: critical
- Description: The containerized SSH service is running OpenSSH 4.7-p1, which is susceptible to brute force attacks. With the correct password file, an attacker can brute-force SSH into the machine and remotely run commands.
- Affected services/IPs: 192.168.0.194:2222
- Evidence:



```
Applications Places System Parrot Terminal
File Edit View Search Terminal Help
valid_lft forever preferred_lft forever
2: eth0@if7: <BROADCAST,MULTICAST,UP,LOWER_UP,M-DOWN> mtu 1500 qdisc noqueue qlen 1000
   link/ether ee:ac:d7:cb:39:e1 brd ff:ff:ff:ff:ff:ff
   inet 10.89.0.14/24 brd 10.89.0.255 scope global eth0
   valid_lft forever preferred_lft forever
   inet6 fe80::ecac:d7ff:feeb:39e1/64 scope link
   valid_lft forever preferred_lft forever
su
su: must be run from a terminal
su -
su: must be run from a terminal
who
uname -a
Linux e994e60131eb 6.12.32-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.32-1parrot1 (2025-06-27) x86_64 GNU/Linux
/home/user
ls /home
ftp
msfadmin
service
user
ls /root
Desktop
reset_logs.sh
vnc.log
[0] 1:ruby* 2:bash~
"cs456-153" 15:24 07-Dec-25
Menu Parrot Terminal
```

- Remediation steps: The container image for the SSH service must be updated to a non-vulnerable version of SSH (any version after 10.x). It is recommended to pull the latest official image for the service and redeploy the container.

Failed Exploit Attempts

4.1. Attempt 1: SSH Brute-Force Attack

- Service targeted: SSH on TCP port 22

- Description of attempt: I initiated an automatic brute-force attack against the SSH service using the same exploit in Metasploit. The attack targeted common usernames.
- Reason for failure: The attack didn't result in any successful logins after running through all the name and password combinations. This suggests that the accounts have strong, non-dictionary passwords or that security measures like fail2ban might be in place, but I didn't see anything suggesting this. I then stopped the attack to prevent potential lockouts.

Conclusions

Summary of Attack Path

An attacker would first scan the target to discover the open SSH port. After the attacker identifies the vulnerable SSH version, they would brute force the endpoint to gain a shell within the SSH container. From there, they would escalate their privileges to root, scan the internal network, pivot to other services, and attempt to break out of the container to compromise the host VM.

Overall Security Posture

The overall security posture of this VM is very poor. The presence of a well-known vulnerable version of SSH indicates a severe lack of basic security hygiene and patch management for the containerized services. This makes the system an easy target for even an unskilled attacker.

Appendix

Tools Used

- Nmap
- Metasploit Framework